

From Specification Violations to Exploitability: Deviation-Guided Testing of TLS Libraries

이재훈, 배경민

포항공과대학교

STAAR 11th Workshop @ KNU

TLS Protocol

- TLS(Transport Layer Security) Protocol: 네트워크 상의 두 당사자 간 메시지 전송 시 데이터 보호/무결성을 보장하기 위한 보안 프로토콜

Internet Engineering Task Force (IETF) E. Rescorla
Request for Comments: 8446 Mozilla
Obsoletes: [5077](#), [5246](#), [6961](#) August 2018
Updates: [5705](#), [6066](#)
Category: Standards Track
ISSN: 2070-1721

The Transport Layer Security (TLS) Protocol Version 1.3

Abstract

This document specifies version 1.3 of the Transport Layer Security (TLS) protocol. TLS allows client/server applications to communicate over the Internet in a way that is designed to prevent eavesdropping, tampering, and message forgery.

This document updates RFCs 5705 and 6066, and obsoletes RFCs 5077, 5246, and 6961. This document also specifies new requirements for TLS 1.2 implementations.

Status of This Memo

This is an Internet Standards Track document.

This document is a product of the Internet Engineering Task Force (IETF). It represents the consensus of the IETF community. It has received public review and has been approved for publication by the Internet Engineering Steering Group (IESG). Further information on Internet Standards is available in [Section 2 of RFC 7841](#).

Information about the current status of this document, any errata, and how to provide feedback on it may be obtained at <https://www.rfc-editor.org/info/rfc8446>.

RFC 5246(TLS 1.2), 8446(TLS 1.3)

TLS Protocol

- TLS(Transport Layer Security) Protocol: 네트워크 상의 두 당사자 간 메시지 전송 시 데이터 보호/무결성을 보장하기 위한 보안 프로토콜

Internet Engineering Task Force (IETF) Request for Comments: 8446
Obsoletes: [5077](#), [5246](#), [6961](#)
Updates: [5705](#), [6066](#)
Category: Standards Track
ISSN: 2070-1721

E. Rescorla
Mozilla
August 2018

The Transport Layer Security (TLS) Protocol Version 1.3

Abstract

This document specifies version 1.3 of the Transport Layer Security (TLS) protocol. TLS allows client/server applications to communicate over the Internet in a way that is designed to prevent eavesdropping, tampering, and message forgery.

This document updates RFCs 5705 and 6066, and obsoletes RFCs 5077, 5246, and 6961. This document also specifies new requirements for TLS 1.2 implementations.

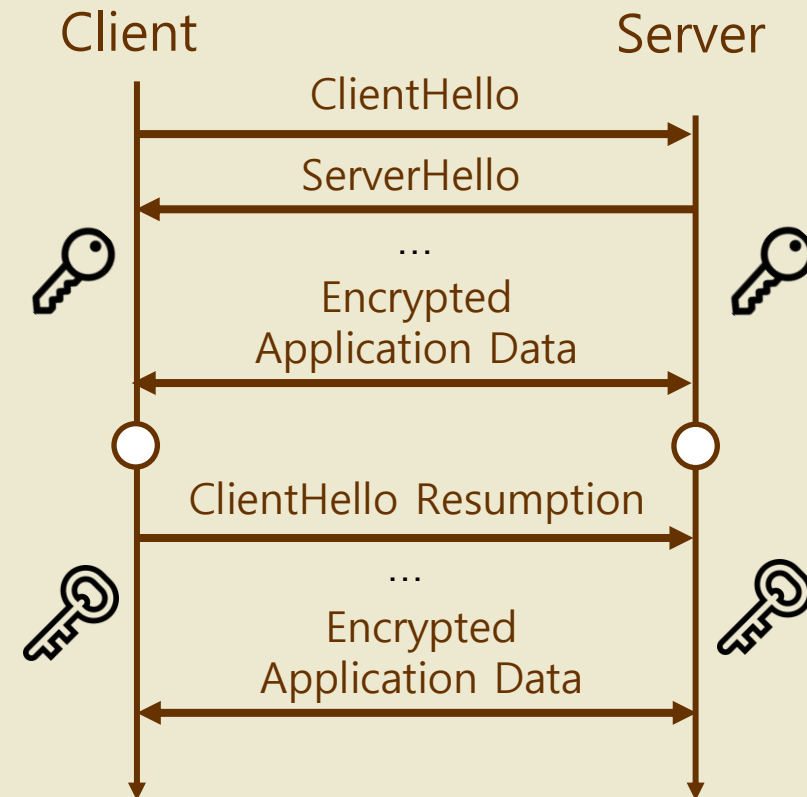
Status of This Memo

This is an Internet Standards Track document.

This document is a product of the Internet Engineering Task Force (IETF). It represents the consensus of the IETF community. It has received public review and has been approved for publication by the Internet Engineering Steering Group (IESG). Further information on Internet Standards is available in [Section 2 of RFC 7841](#).

Information about the current status of this document, any errata, and how to provide feedback on it may be obtained at <https://www.rfc-editor.org/info/rfc8446>.

RFC 5246(TLS 1.2), 8446(TLS 1.3)

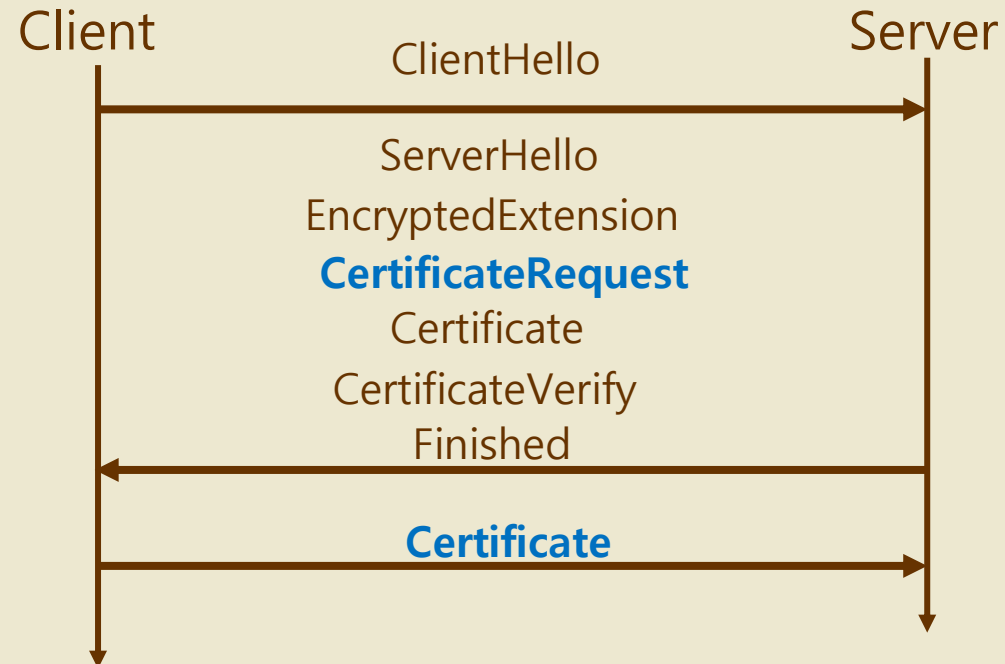


RFC Specification

- TLS Protocol은 각 메시지 별로 만족해야 하는 요구사항이 존재함

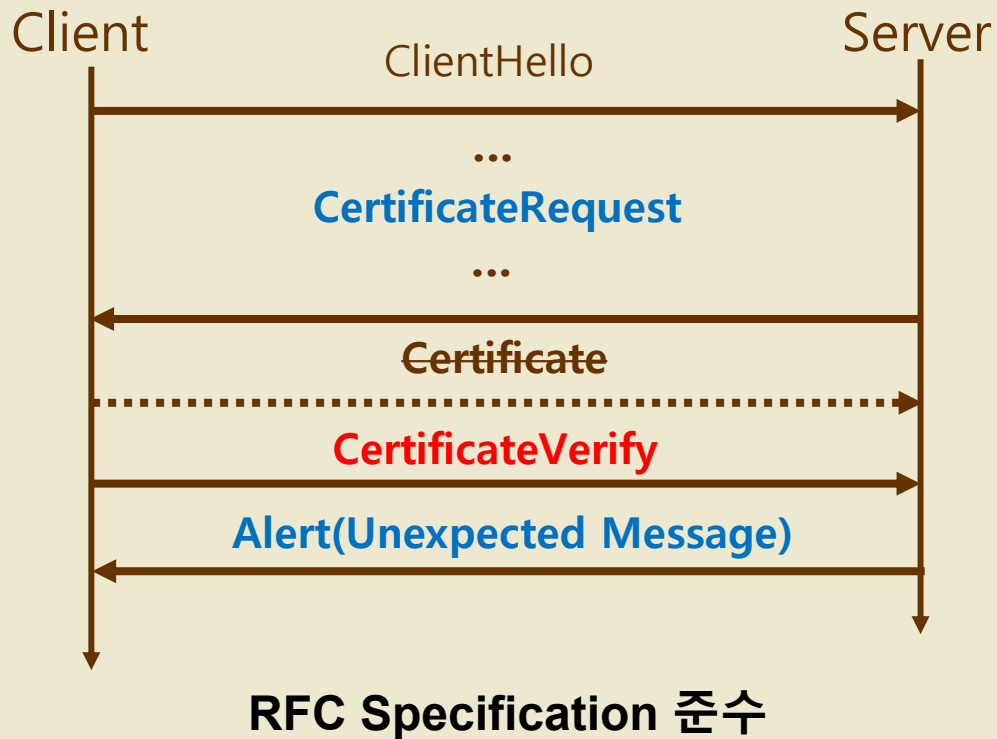
The **client MUST send** a **Certificate** message **if and only if** the **server has requested client authentication** via **CertificateRequest** message.

- RFC 8446 Section 4.4.2 Certificate



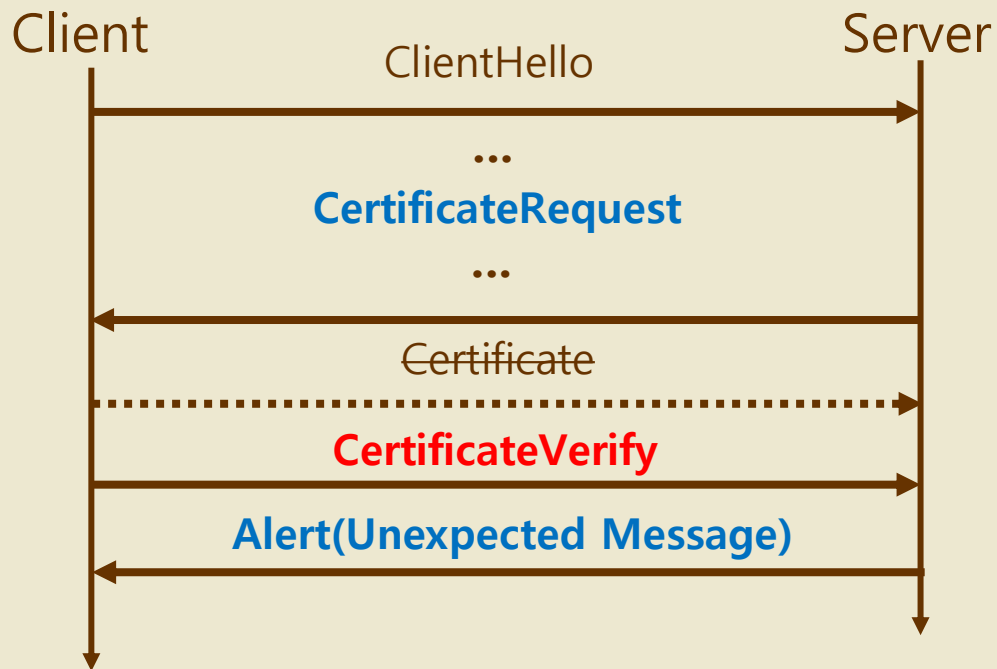
RFC Specification Violation & Exploitability

- RFC 요구사항을 위반하면 보안 문제가 생길 수 있음

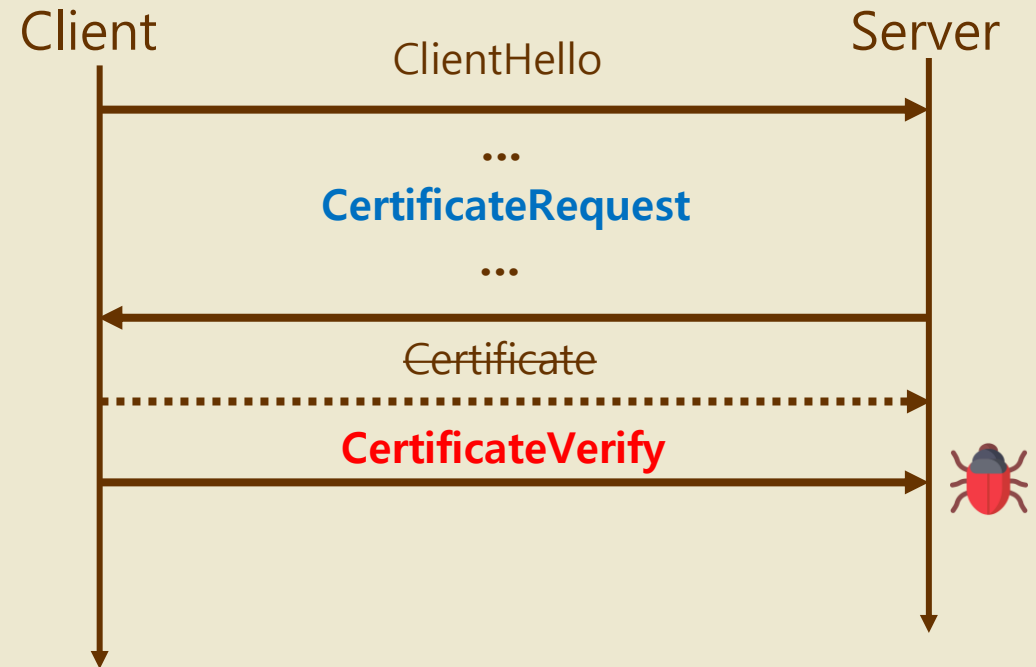


RFC Specification Violation & Exploitability

- RFC 요구사항을 위반하면 보안 문제가 생길 수 있음



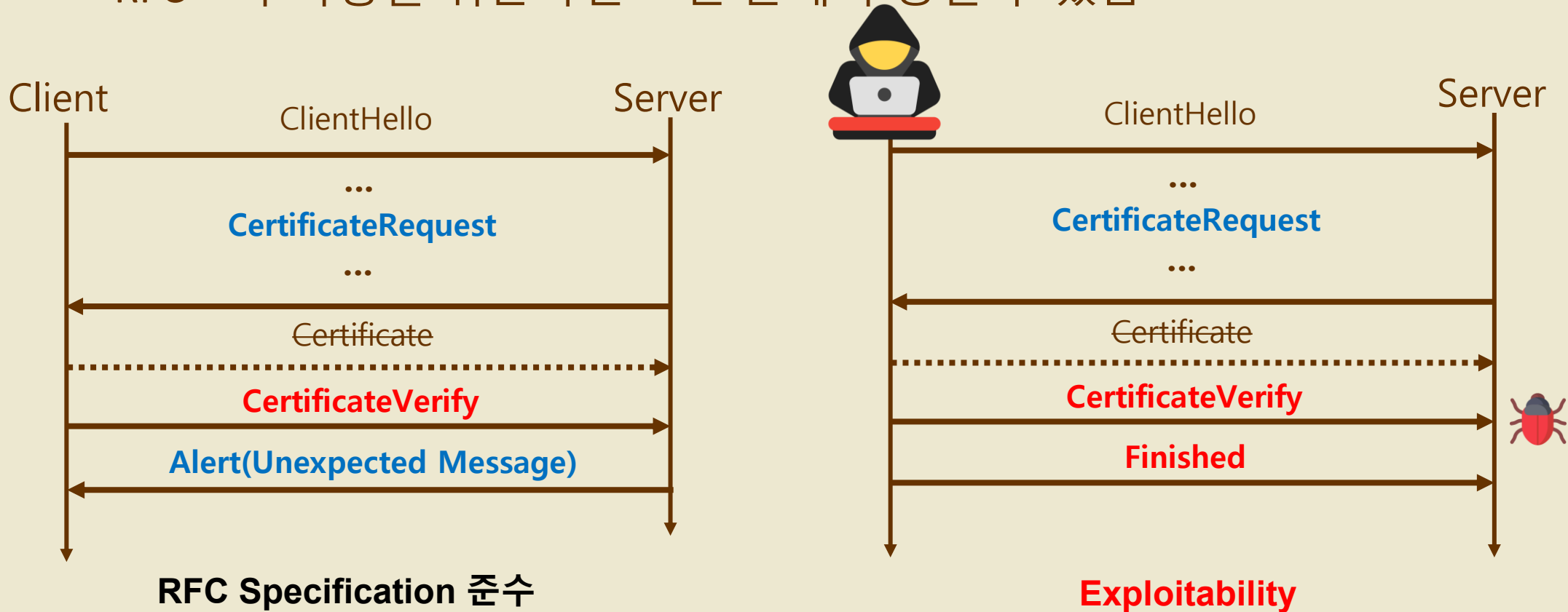
RFC Specification 준수



RFC Specification Violation

RFC Specification Violation & Exploitability

- RFC 요구사항을 위반하면 보안 문제가 생길 수 있음



Challenges

1. RFC Specification Violation 탐지를 위한 Exhaustive & Precise Oracle
2. Context-specific negative test case
3. Initial → Spec-Violation → Exploitability 까지 도달하기 위한 Scenario 명세



Challenges

1. RFC Specification Violation 탐지를 위한 Exhaustive & Precise Oracle

➡ **MoudE3** Formal Model

2. Context-specific negative test case

➡ off-specification behavior deviation
skip Message when client.certificateRequested = true

3. Initial → Spec-Violation → Exploitability 까지 도달하기 위한 Scenario 명세

➡ scenario property
initial → any* → skipMessage → any* → complete

Our Approach

- TLS Features들과 세부 요구사항들을 Maude기반 Formal Model로 명세함
 - Maude: Rewriting-Logic Framework for specifying and analyzing distributed systems and protocols

[sendMsgType]:

$\langle o_{src} \text{ to } o_{dst} : \text{Link} \mid \text{msgQueue} : \text{MSGs} \rangle$

$\langle o_{src} : \text{NodeType} \mid \text{status} : st, a_1 : v_1, \dots, a_n : v_n \rangle$

$\Rightarrow \langle o_{src} \text{ to } o_{dst} : \text{Link} \mid \text{msgQueue} : \text{MSGs} :: \text{MSG} \rangle$

$\langle o_{src} : \text{NodeType} \mid \text{status} : st', a_1 : v_1', \dots, a_n : v_n' \rangle$

if $\text{MSG} := f_1(m_1) \cdots f_n(m_n)$

Send Message Rule Patterns

Group	RFC Section	Req	Model.	Cov
Key Exchange	Section 2, 4.1	50	42	84.0%
Extensions	Section 4.2	96	71	74.0%
Server Parameters	Section 4.3	8	8	100.0%
Authentication Messages	Section 4.4	41	34	82.9%
Early Data / Post-Handshake	Section 4.5-4.6	23	16	69.6%
Record / Alert Protocol	Section 5-6	50	28	56.0%
Crypto / 0-RTT / Compliance	Section 7-9	30	8	26.7%
Others	Section 4	29	22	75.9%

RFC Requirement-Model Coverage

Our Approach

- Context 기반 off-specification behavior를 통해 Formal Model 자동 수정
 - 2016 ~ 2026년 동안 발생한 CVE를 분석하여 이를 표현하는 4개의 패턴을 정의함

BehaviorId:

SkipMessage

Parameters:

\$msgType : MessageType

Condition:

event = send ∧ client.certRequested = true

messageType = \$msgType

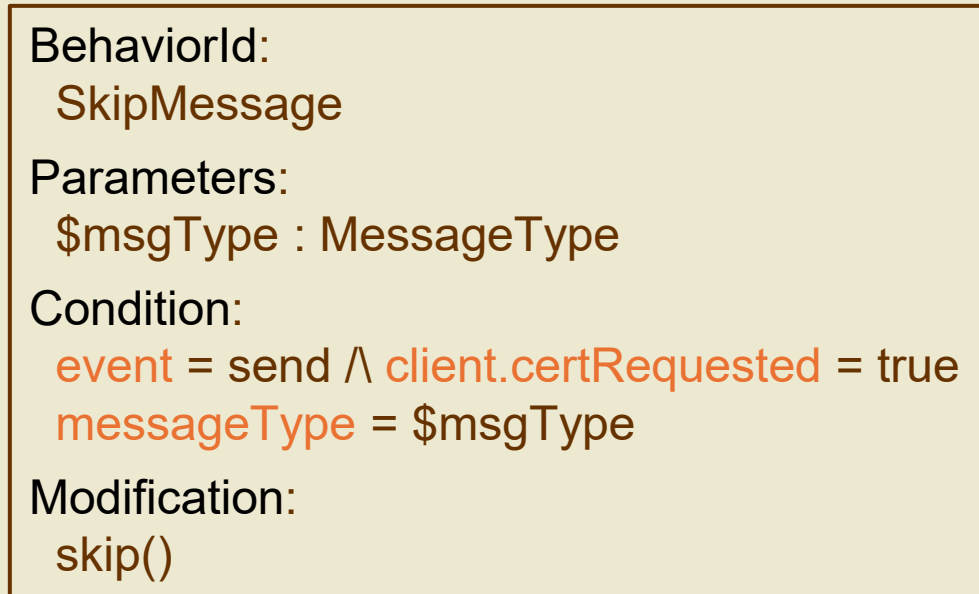
Modification:

skip()

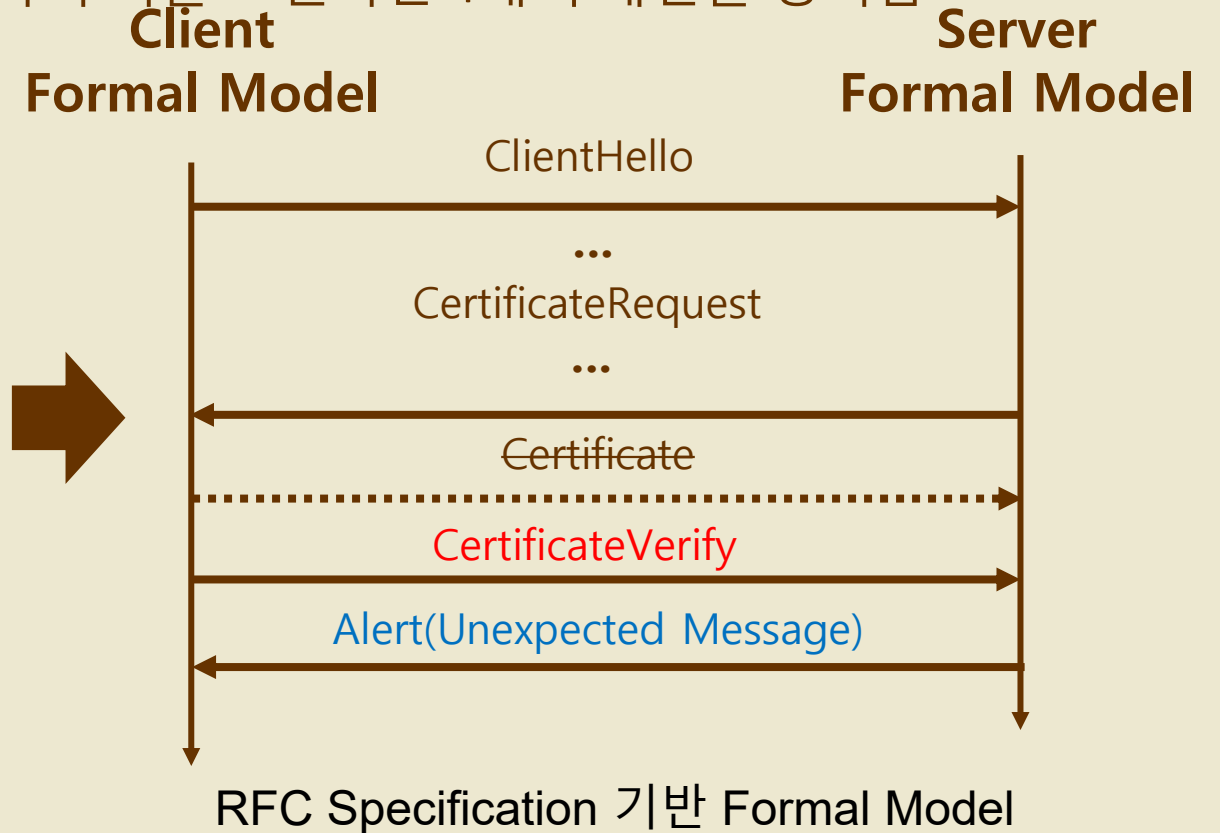
Behavior Deviation Pattern(P4)

Our Approach

- Context 기반 off-specification behavior를 통해 Formal Model 자동 수정
 - 2016 ~ 2026년 동안 발생한 CVE를 분석하여 이를 표현하는 4개의 패턴을 정의함



Behavior Deviation Pattern(P4)



Our Approach

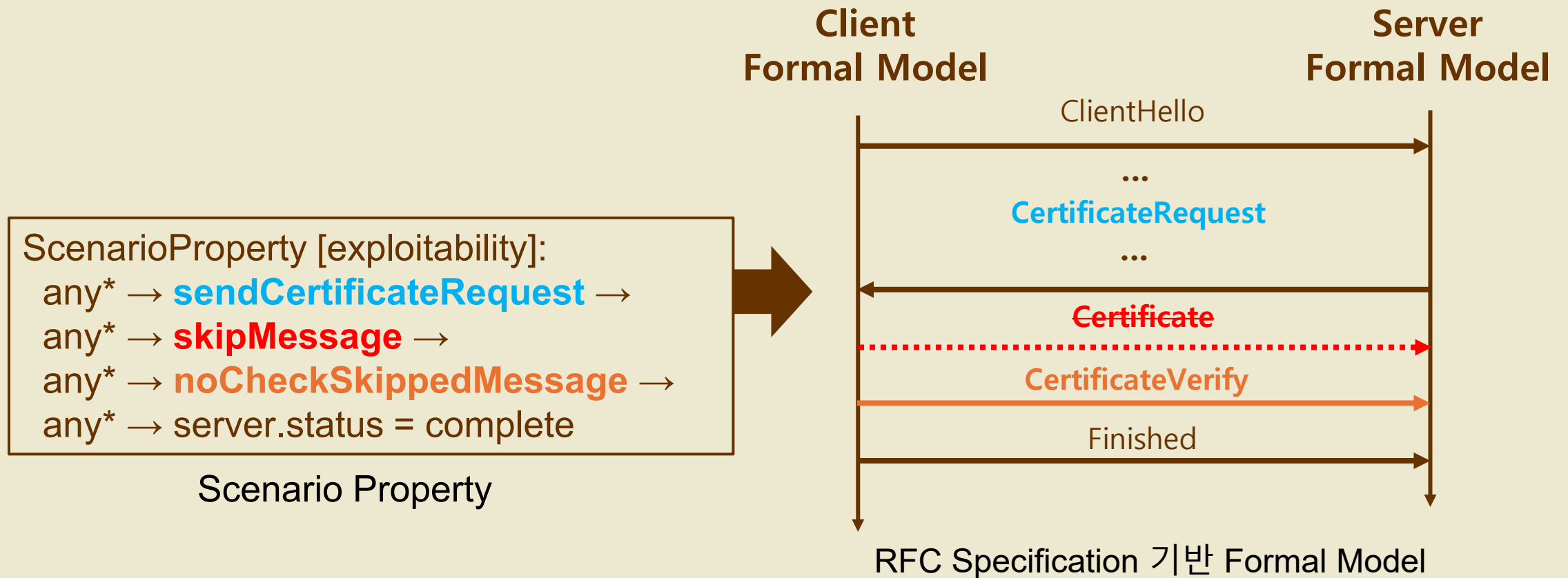
- Scenario property를 통해 formal model 행동 제약 명시

ScenarioProperty [exploitability]:
any* → sendCertificateRequest →
any* → skipMessage →
any* → noCheckSkippedMessage →
any* → server.status = complete

Scenario Property

Our Approach

- Scenario property를 통해 formal model 행동 제약 명시



Experimental Evaluation

- RQ1: 현재 접근법을 통해서, 새로운 specification-violation bug를 탐지할 수 있는가?
- RQ2: specification-violation bug에서 exploit이 가능한 상황까지 갈 수 있는가?

Library	TLS 1.2			TLS 1.3		
	Test Failure	Handshake Completion	RFC Violation	Test Failure	Handshake Completion	RFC Violation
WolfSSL 5.8.2	14	8	8 (4)	25	10	10 (10)
MbedTLS 4.0.0	30	30	3 (3)	89	53	5 (4)
GnuTLS 3.8.11	14	14	1 (1)	28	27	5 (4)
Total	58	52	12 (8)	142	90	20 (18)

Experimental Evaluation

- RQ3: 기존의 테스트 도구들이 탐지하는 specification-violation bug를 재현할 수 있는가?

Tool	Base Tools(VT)	Our Tools(VO)	$ VT - VO $	$ VO - VT $	$ VT \cap VO $
TLS-Anvil	23	82	7	66	16
TLS-Attacker	7	18	4	15	3
DY-Fuzzer	6	56	3	53	3

Experimental Evaluation

- RQ4: 기존에 발견된 CVE들을 재현할 수 있는가?

Target	Exploit Category	Behavior Deviation	Reproduced Tests
GnuTLS 3.7.9	Memory Crash	Remove Extension	5
WolfSSL 5.6.0	Key Compromise	Remove Extension	1
WolfSSL 5.5.0	Memory Crash	Change Message Field	3
WolfSSL 5.1.0	Client Impersonation	Change Message Field	5
WolfSSL 5.1.0	Client Impersonation	Skip Message	1
WolfSSL 5.0.0	Infinite Loop	Change Message Field	1
WolfSSL 4.6.0	Server Impersonation	Change Message Field	10
WolfSSL 4.4.0	Server Impersonation	Skip Message	1
MbedTLS 4.0.0	Downgrade Attack	Change Message Field	5

From Specification Violations to Exploitability: Deviation-Guided Testing of TLS Libraries

이재훈, 배경민

포항공과대학교

STAAR 11th Workshop @ KNU